m-web.etonedu.cn/mfinm

.

1

€ • , ƒ „ 2

… † ‡ ˆ ‰ Š ‹ € Œ • Ž • 4

• ‘ ’ “ ” € ” • – — 7

˜ ™ š › œ € • ž Ÿ – — 9

¡ ¢ £ ¤ ¥ € ‘ ’ ¦ § ¨ © 12

ª ƒ « € ¬ - ® ¯ 14

° ± — ² € ³ ´ µ ¶ 15

1.1

· ¸ ¹ º œ » ¼ ½ ¾ ¿ À ° Á Â À Ã Ä ‡ • ¸ ÅÆÇ È m-web.etonedu.cn/mfinm É Ê Å Ë Ì Í Î Ï Ð Ñ Ò etonedu.cn Ó ¸ ¢ £ ¤ ¥ Ô Õ Ö • ¸ × Ø Ù Ð œ Ú • ž ' Û Ü Ý Å Þ ß à á â ã ¤ 100 ä å 200 ä å 500 ä € æ ç à á è Å é ê Ó ë ì í Û î ï ð ñ ò ó Ö · ô ¸ Û š URL œ Ú

> Û š URL â visitId Â õ ö ÷ URL ø ‰œ %7C è
>
> https://m-web.etonedu.cn/mfinm/?visitId=1790161526056%7C26#/hfRecharge/home

Û š URL Â ¸ visitId=1790161526056|26 ù ú û · ô ü ý ¸ þ é ÿ Ö Ë õ ö ¸ „ Ú † 1790161526056 œ 13 Unix Å ì œ 2026 9 23 â è ì 26 œ ø Ý Å œ • ž ! Ö " ƒ „ # $ ì % & Â ƒ ' † ‡ ˆ ‰ € ™ š › œ í ë Ö

1.2

· ô ó ( ) › * + , Ú æ û - Ä Å . / “ Õ • ¸ å Ó Õ 0 1 2 3 4 5 å ¨ © HTTP - 6 7 € TLS — 8 ¦ § æ û • ¸ 9 : ¸ ; < = > Å ? $ @ A B Â C 1 • ¸ å D • ¸ E ¶ ¸ ; < F • G H ' Û 9 I ¸ J K Ü Ý â 00000000 è L M N • ¸ 9 : ¸ Ü Ý – O P Ö Q R “ ” — — S – T U ¹ · G 9 V N W ¸ = > ” X í › Å Y ™ M Z [\ S • ž ú ² Ö

] Ó + ¸ $ · Â ^ ð Y) › Å L $ _ 6 & Â] Y – — ` Ú

a b Û * c â SQL b Û å XSS Õ d e f è € Z [g h › œ

a ¹ î ï å i å D j k Ý © l • ž m Œ • RPC G n ¸ o Ò p q r – —

a SSRF s é ¸ S t – — â (u W v w ¸ Å Y „ x y N = > è

a ¹ æ ç • ž visitId ¸ z å þ { | } ~

a ¹ \ S Ü Ý ¸ Ÿ â (• 00000000 – — • € • - 6 ¸ , r è Ö

ƒ „ … ¸ † ‡ û Ú Y ÷ 8 ¸ ˆ ‰ ¹ … G í › Š Ä ‹ Œ $ Â » • Ž • • ‘ ’ “ ” • n – — ˜ ™ ˜ š å ” n – m n › n œ • Ö · ¸ ž $ È Ÿ p ¸ - Ä

agent-browser â ' ´ Playwright Chromium Å J 7 µ H è	• ¸ “ Õ å ä ¶ · ¸ å = > ü ý å@A B ' ¹ º € » .
curl 8.x	HTTP = > þ { å - 6 7 ¨ © å CORS ã ¨ c
OpenSSL â s_client / x509 è	— 8 € TLS ¼ · ½ j ¨
ripgrep â rg è	† ‡ bundle Â ¾ ø ‰ ” • € ¿ À ƒ „ ¸ ; Á ¨ Â
Python 3 + pycryptodome	AES-CBC Ã ” – — Ä ·) ›
bash	¡ ó ° ± ¸ Å Æ € Ç È) ›

E 1-1 ³ ´ € ¥ ¦ µ ¶

€ • ¸ ƒ „ … †

2.1 • ¸ ‡ ^ ‰ Š ƒ „

É Ê] Ã Ä ‡ Ë š “ Õ Ì • ¸ Å m Í Î Ï ì Ð • p ¹ º ä ¶ · ¸ € • ¸ Ñ Ö Ë È Ì û Ã Ä ‡ H5 • ¸ Å Ê µ Ò iPhone 14 ¤ Ó ³ ´ Ô Õ Ö Å Ÿ ° ± ³ × ® Ó Ú

```
° ± 2-1 • ¸ “ Õ € · ¸

agent-browser set device "iPhone 14"
agent-browser open "https://m-web.etonedu.cn/mfinm/?visitId=1790161526056%7C26#/hfRecharge/home"
agent-browser wait --load networkidle --timeout 15000
agent-browser wait 3000
agent-browser snapshot -i
agent-browser get title
agent-browser screenshot /home/z/my-project/download/hfRecharge_home.png --full
```

° ± ' W Ø ¯ • ¸ Ñ œ » ¼ ½ ¾ ¿ À ° Á Â À Å p ¹ º ä ¶ • … Ú Ü Ý X · Ù å à á ' Û Ù â Ú Û œ Ü • 3 è € Ó ë D Ý • ¸ Þ ß ¯ 100 ä å 200 ä å 500 ä å æ ç à á • · à à á Þ á Ö Ÿ ' W ® Ó Ú

```
' W 2-1 ä ¶ · ¸ â ref ø Ý â · ¸ ã Î è

- textbox "        " [ref=e2]
- spinbutton "    (  )" [disabled, ref=e3]
- button "      " [ref=e1]
100   / 200   / 500   /
```

p ä ™ ü ý ¸ › œ å & æ ` ± Ú æ Å à á ' Û Ù $ Ü Ý ç è ÿ † é È Ü • 3 Å ê ^ † ‡ ë $ Ü Ý ì à á ¸ í Ä – O P Å " O P ¸ M N é ? … # î ¸ Ü Ý – ™ š =>

2.2 ‹ Œ • Ž • •

$ • ¸ “ Õ Ÿ ì ô • @ A B ` ± ¸ = > µ ¶ Å ² õ ö ÷ • ¸ ¸ 4 5 € ™ š ø ù ú Ö ° ± œ `agent-browser network requests` Å ¿ À = > ÷ û ì ® Ó E Ú

• Ž	‘ ’	“ ”	•
GET /mfinm/?visitId=...	Document	200	SPA Û š HTML â 1.3 KB 2 3 ü è
GET static.etonedu.cn/.../app.06685cf4....js	Script	200	Š Ù Ð bundle Å 2.27 MB
GET static.etonedu.cn/.../vendor.f4b3c239....js	Script	200	...G ø ù bundle
GET static.etonedu.cn/.../6.95147e55....js	Script	200	• ¸ ¹ 6 ¸ ý ë chunk
GET res.wx.qq.com/open/js/jweixin-1.2.0.js	Script	200	þ JS-SDK Å 2017 ¸ 1.2.0 ¼ ·
POST /mfinm/getLoginInfo	XHR	200	ÿ ± 3 Ð • ™ š
POST /post	XHR	200	§ • RPC ¿ â • ¸ “ Õ ? • ô è
GET /favicon.ico	Other	404	é ú

E 2-1 • ¸ ¿ À = > µ ¶

ò = > µ ¶ p] æW... á ƒ « Ö Å Ù Ð ˆ ‰ Æ Ç $ 2 3 Ñ static.etonedu.cn ƒ Å € ™ š Ñ m-web.etonedu.cn Å 2 3 4 5 J Z [÷ ? p 0 1 Ó Õ Å " û ... ˆ ‰ Š ‹ ¸ Û š Ö Å • ¸ ë $ Ù Ð ™ š Ú É Ê /mfinm/getLoginInfo ¸ ÿ ± 3 ™ š € $ É Ê Ó ¸ § • ¿ /post Å ì $ • ¸ “ Õ ? - • ô Å ê ^ Ô Õ • × Ø ¸ ó • O P Ö ...Å þ JS-SDK • ¸ û 2017 N ¸ 1.2.0 ¼ · Å € › 1.6.x _ ™ Å Á È ^ Ø ¡ ¸ ø ù Ö

2.3 – — ˜ ™ Cookie š ›

â ì ¨ ©@ A B ¸ } Î 3 Å . / Cookie å localStorage € sessionStorage Å Ì ¸ $ È ð ñ • ¸ û $ ž ‡ ë Z [² Ö) › ° ± € ƒ ! ® Ó Ú

```
° ± 2-2 · "  3 ¨ ©

agent-browser cookies                 # -> No cookies
agent-browser storage local           # -> No storage entries
agent-browser eval "JSON.stringify({cookie: document.cookie,
  session: Object.fromEntries(Object.entries(sessionStorage)),
  local: Object.fromEntries(Object.entries(localStorage))})"
# -> {"cookie":"","session":{},"local":{}}
```

… * ë # Æœ Î Ö " ê ^ ¸ 3 Ÿ ë $ Ï Ð ‡ Å ž ‡ $ % & ¸ ö Â ' û URL Â ¸ visitId ù ú (ù ú) * - z Å Ï Ð ‡ L J @ A B ¸ þ ² , œ + , ö Ö " ü ý „ ˜ Â visitId - — Ñ ¸ ä ™ — ² ÿ Ö

œ • ž Ÿ ¡ ¢ £ ¤ ¥ ¦

3.1 § ” ¨ © ª ¦

. ð ñ Ù Ð bundle Æ Ç $ 0 1 2 3 Ñ / J ÷ Ö F • curl ä ™ Ó Õ Š bundle € • , ¹ 6 ¸ ý ë chunk Å 0 X 1 „ ì % Æ ˆ ‰ Š ‹ ¸ ¹ º Ú

```
° ± 3-1 Ó Õ † ‡ bundle

curl -s "https://static.etonedu.cn/statics/wxedu/mfinm_v0.1/static/js/app.06685cf4bb1b7f0cf36c.js" \
  -o app.js        # 2,376,253
curl -s "https://static.etonedu.cn/statics/wxedu/mfinm_v0.1/static/js/6.95147e55f7520cf50ac1.js" \
  -o chunk6.js     # 25,694
```

2 î 3 ¸ û Å " X 1 ¹ Z [º í • ž J š 1 0 1 Å æ Â ¸ Æ ’ 4 m ² È # ì ‡ ¦ § ä ™ 5 6 $ 0 1

```
° ± 3-3 I J Ž • ¦ § ¹ º

rg -o "wxapp_secrets:\{[^}]{0,900}" app.js
rg -o "redissettings:\{[^}]{0,120}\}[^}]{0,60}" app.js
rg -o "(172\.|10\.|192\.168\.)[0-9.]+:[0-9]+" app.js | sort -u
```

> **¶ · SR-01 ¸ ¹ º » ¼ • ž Ÿ ½ ¾ ´ ¿ ± ž À - ² ³**
>] Ó Æ] ^ X K H ' ´ È 0 1 p Ó Õ ¸ app.js Â Å Z [p ä ™ Đ • Ú
> ¡ Å þ 0 L Ý AppSecret â 6 (ë $ È Ï Đ ‡ è
> Redis ú ² M " N å ‡ š € " ‰
> ' Ï Đ B " N å 0 ^ X API " N å î ï ¿ " N
> O ' Æ ± P â innerTokens è € ÿ ± ‰ Ö

Å) * œ þ 0 L Ý ² Ö AppSecret û 0 L Ý ™ š • Q Â ¸ ² Å € AppID ¦ ¹ p • È Đ • access_token Å í R + , 0 L Ý ¸ S T N å U ¶ V û å ¿ b ô • m Æ 1 { ™ š Ö ¡ Å Ÿ À ® Ó Ú

Á Â Ã Ä AppID	AppSecret
wxf9b0ca0e92a8daa5	c372a5d9a2eae11fff4f4fe79d690b82
wxda4a62665557462c	a841b57fba146aef0095f47f6dd462e4
wx0de5c02e09ce782a	7185cc98c976ad7e679cb18f90ad03e8
wx285e2f4cdbf4d73f	854a0f17e204c33f2847723073426db6
wx9438aaff9643e223	1df8f9ca6d25b60690ded74f319550ab
wxb9da19be57340462	04374491c2600c7b4bc9fe88d366f7be

E 3-1) * ¸ þ 0 L Ý AppID € AppSecret â app.js ' ´ wxapp_secrets ¹ º è

Å) * œ ¢ £ ¤ ¥ W ™ € ' Æ Ï Đ " N Ö Redis œ ' " N Å ò 0 8 p ä q Å X " N € š ± ¸ Y * Z [\ ( ] ê Đ æ Z ' ^ é â _ ® ÷ ¡ Q s ` SSRF É Ê è Å ? p ä ™ ÿ ± a ë Ï Đ 106.53.6.112 Á û 0 p q /] ^ X HTTP Ô Õ Ù Đ ¸ ™ š Ï Đ B Ö

' Å	—Æ	Ç È / É Ê	Ë Ì
Redis a ë	172.16.50.31:13697	" ‰ TtLNOyJwZgFe2g0	db 3 / 4 / 6 / 8 • M
' Ï Đ	172.18.143.178:28120	â ¦ § Â Y b š ± è	' " N Å 0 8 p ä q
0 Ù Đ API	106.53.6.112	http ^ X /api/consume/saas/...	~ Ã " ƒ ! ð ñ
§ í î ï ¿	116.228.64.55:6900	/yungateway/member/signContract.html	¡ • , É Ê
‹ ƒ	localapi.etonedu.cn	/stat	localInterfaceSwitch 1 ¿ á

E 3-2) * ¸ ¢ £ ¤ ¥ â app.js ' ´ ¦ § ¹ º è

… Å) * œ ' Æ ± P Q Ö O ± P c d ÿ ± å e f å å ‹ © å g h m i ¸ ' Æ º ² Å ° Ò ä ™ E ^ • - Å Æœ 50 j k ¸ l m n o p Å Ÿ ® Ó E Ú

Í Î Ï Ð	Ñ
login_app_key	fdakQeoPBW7X9DAiNjmp4XKwNepMaYWKJcXD5qYE0Mf8LfZt

Ô Õ Ö ‡ - … † - ® × Ø

4.1 ‡ - Ù Ú Û Ü

~ â ™ š › œ è # y ì /post ¿ ¸ = > Q û Base64 ” X Å ‡ õ 2 î Ê $ † ‡ ˆ ‰ Â I æ “ ” S Ö] AES.encrypt œ — é ¨ Â Å ° Â … é ² „ ¸ “ ” ˜ ú I ™ Å] Ó œ ÷ š H Î ì ¸ × Ø S â † X œ › œ ˆ ‰ Å O P Y • Z [ž Ä è Ú

ˆ ‰ 4-1 app.js Â ¸ ‘ ’ “ ” ˜ ú â š H Î è

```
function encrypt(t, e, n) {
  e = e || "JsNmKzx^zJ#QDdMh"           //      e
  n = n || "JsNmKzx^zJ#QDdMh"           //      n  IV
  e = CryptoJS.enc.Utf8.parse(e)
  n = CryptoJS.enc.Utf8.parse(n)
  var a = CryptoJS.enc.Utf8.parse(t)     //
  var r = CryptoJS.AES.encrypt(a, e, {
    iv: n, mode: CryptoJS.mode.CBC, padding: CryptoJS.pad.Pkcs7
  })
  return CryptoJS.enc.Base64.stringify(r.ciphertext)
}
```

> **¶ · SR-02 ¸ ¹ ° » ¼ Õ Ö ‡ - - ® « ¬ Ý Key IV Þ Ñ**
>
> n œ AES-128-CBC Å PKCS7 ç Å Base64 ’ W
>
> ” • € Ú Û J È T œ “ I n o p JsNmKzx^zJ#QDdMh â 16 n & è Å Q R • ž • Ÿ
>
> ” • â 0 1 JS N Å “ ” (¦ Ó ¹ - Ä » . ¥ ¦ ¸ ¡ ¢ , • Å 8 „ ¹ • ¸ ” Ö

I ° ± · : ² £ æ ` ± Å ß ¯ • S Ú Q ¤ “ ” $ ˆ ‰ Š ‹ Ë ¥ Ó û 9 ¦ 0 1 ¸ Ö ¨ Â ° ± ® Ó Ú

° ± 4-1 “ ” ˜ ú I

```
rg -o ".{200}AES\.encrypt.{260}" app.js
```

4.2 ß - × Ø ¸ à á – â ã • Ž »

œ – — Q Ž • ” • ¸ \ S R K r Å • ˜ Â Ë · G ’ Û J K Ü Ý 00000000 § ¨ ¸ š = > ” X Å ø è Ä ·) › Ã ” Ö Ä · Ÿ ’ 4 ® Ó Å ” X œ · G 9 I = > ¸ † Û ù ú Å J Z [ç • ú ² Ú

ˆ ‰ 4-2 verify_aes.py Ÿ Ä ·

```
#!/usr/bin/env python3
# verify_aes.py -          AES       €  • ‚ ƒ „ … † ‡
import base64
```

```
from Crypto.Cipher import AES
from Crypto.Util.Padding import unpad
KEY = b"JsNmKzx^zJ#QDdMh"   # app.js
IV  = b"JsNmKzx^zJ#QDdMh"   # ^   IV
ct_b64 = ("I8cRd7Ic7onNWXmszeqWVTD2nqsXIuKe0w5OzWpiImo5IqKp88T6t7XQ4emiL+biM/"
          "fL9bBcWFhQdSgF/DnVHy3yZm8Gv0JOINio8zmBNUcIwH14k1Q5mkYCZ38gcAeKFzLasrpA8aF"
          "1ZCPFvKu0blxRVfVmULD1igW2sBZrXAy/r10eUSiULp3u1YXiuVfj")
ct = base64.b64decode(ct_b64)
cipher = AES.new(KEY, AES.MODE_CBC, IV)
pt = unpad(cipher.decrypt(ct), 16)
print("Decrypted plaintext of our own test request:")
print(pt.decode("utf-8"))
```

e › G H œ pip install pycryptodome Ì) › python3 verify_aes.py Å ô e › ? © F † ^ X Å ' W ® Ó Ú

```
 ' W 4-1 Ã " ƒ ! â . – — è

Decrypted plaintext of our own test request:
{"url":"http://106.53.6.112/api/consume/saas/check/user","schoolCode":"440106lloza",
 "userSn":"00000000","CODE":"I_BSS_BSS_GDRC_HTTPPOST"}
```

Ã " ƒ ! ² Y * • … þ î „ S Ö Å " • – — © Å ‘ ' “ " ¹ Z [Ð • ¡ app.js ¸ • Ÿ Œ ^ Å / Ë È " • “ I Å Z [• • p] ª J „ x Z Z ' n " X Å ? “ " « 8 " ¬ 8 , … x Ö Å = > ^ X Â % & Ÿ ¸ Ù Ð ù ú ƒ „ Ú À ˆ ‰ å Ü Ý € RPC G n Ò Ö … Å } æ b Z ¸ û url n - - ž ‡ # y N Ì " N , œ ù ú Ž ¹ ® ì ‡ Å ì ‡ ¿ D õ " N N ¯ = > " N œ 0 ^ X HTTP Ï Ð Ö " ƒ „ „ ï ¸ Ï Ð ‡ = > … x â SSRF è v w , Å · D ' œ „ … (` ± s é Å Y „ x Z [u J ' " N ¸ y N = > Ö

4.3 ‡ - ä å ƒ æ

° ' · S – Å ‘ ' ± “ " ¸ S t 3 z œ • Ú " • 0 1 å IV “ I / € " • _ ² å Æ = > € - 6 ù ú p Ã p x Ö • – — ƒ ! € …) * ¸ ' Æ ± P _ º ó — Å ê ^ ¸ ² ¤ , ³ Â L 8 ë $ \ ; Z ™ ƒ ¸ ž ‡ ì Ï Ð ‡ " ± Ö ¹] ê R ´ Å $ 2 î • ¸ Æ ¥ , ' û Ó Õ 0 app.js Ö

ç è é ê ë … † ì í î × Ø

5.1 getLoginInfo è é º ï

É Ê $ @ A B ÿ q þ { • ¸ “ Õ ¸ ÿ ± 3 ™ š Ö = > Q D • ¸ › œ „ x â ì ÷ @ A B ’ – — ð ñ æ S t = > Q œ Î ¹ º è Å L % & € • ¸ µ ¸ Origin € Referer 7 Ú

```
° ± 5-1 getLoginInfo þ {

curl -s -X POST "https://m-web.etonedu.cn/mfinm/getLoginInfo" \
  -H "Content-Type: application/json" \
  -H "Origin: https://m-web.etonedu.cn" \
  -H "Referer: https://m-web.etonedu.cn/mfinm/?visitId=1790161526056%7C26" \
  -d '{"visitId":"1790161526056|26"}'
# ‰ Š
# {"status":false,"rescode":403,"data":null}
```

þ { - ¶ · â Ù Ð ‰ 403 è Ö " ¸ r ƒ ! · : % & Ú ™ š ¸ – 8 ø ù = > Q ù ú Å R ø ù @ A B É ô “ Õ • ¸ I ¸ Ï Ð ‡ ƒ Ó X â p • € visitId : WAF ¹ I è Ö ´ ÿ Å ÿ ± 3 ™ š ë $ – Å X š ¢ É ¸ ž ‡ ² (R URL Â ¸ visitId á Å € · " ë # œ Î ¸ ü ý µ Ö

5.2 ð ñ ò ó • Ž „ ô • • ¸ XHR õ ö »

œ F † • ¸ 9 : ¸ = > „ x å & Å $ @ A B ’ b Û XHR º i Å ` ± ÷ setRequestHeader ¤ § ¸ Æ = > 7 € = > Q Ö + » ² • Vue S _ ¸ store þ ¸ ¼ N getLoginInfo Ä ¸] ½ M N = > Ö b Û G H œ agent-browser eval) ›] Ó Ä · Ú

```
ˆ ‰ 5-1 capture.js â XHR » . + » Å Ÿ Ä · è

(function () {
  window.__cap = [];
  var oo = XMLHttpRequest.prototype.open,
      os = XMLHttpRequest.prototype.send,
      osh = XMLHttpRequest.prototype.setRequestHeader;
  XMLHttpRequest.prototype.open = function (m, u) {
    this.__u = u; this.__m = m; this.__h = {};
    return oo.apply(this, arguments);
  };
  XMLHttpRequest.prototype.setRequestHeader = function (k, v) {
    if (this.__h) this.__h[k] = v;
    return osh.apply(this, arguments);
  };
  XMLHttpRequest.prototype.send = function (b) {
    var e = { url: this.__u, body: b ? String(b).slice(0, 400) : null,
              headers: this.__h, resp: null };
    window.__cap.push(e);
    this.addEventListener('load', function () {
      e.resp = (this.responseText || '').slice(0, 1500);
    });
```

Á â À Ý m è ¨ Í Þ Å p Ì · Ð æ R K Ü Ý µ ¶ Å œ ì % ‹ Œ I J] ê Ž £ ‰ ð Ì Ö

5.4 RPC ,

• Ã ” ƒ ! Â ¸ CODE n Î ¯ /post ¿ ‘ • G n Ò Ï N ¸ RPC µ H Ö ² õ $ † ‡ ˆ ‰ Â ¨ Â Æ] I_ 1 7 ¸ G n < È Å æ ì G n , Ð È € µ ¶ Ú

```
° ± 5-3 RPC G n µ é

rg -o '"I_[A-Z_]{4,60}"' app.js | sort -u | wc -l
# ‹ š  114
```

† ‡ • Y * 114 RPC G n Ò Å c d Ñ © å i å • ž © I å Ò V û å Ó ¥ m Æ Ù Ð Ñ Ö Á . – — p o Ò • ¸ Ü Ý – G n q Å æ Ô G n ¸ o Ò p q r Y â 2 ˆ ‰ è Å X G n Ò · : ? „ Ÿ ¸] ê , " ú Ö Œ • G n Õ ± ® Ó Ú

Ï		•
I_BSS_BSS_GDRC_HTTPPOST	§ • HTTP y N	. – — o Ò p q Å ž ‡ p url n
I_BSS_BSS_PAY_PAP_SIGNING	î ï ˆ Ö i	¨ ” Ö × Ø Ù i Û š
I_BSS_BSS_PAY_PAP_CONTRACT_DEL	Ú Á ˆ Ö '	p Â ñ « R Ö × ¿
I_BSS_BSS_PAY_PAP_CONTRACT_QUERY	© I ˆ Ö '	p c © ç • i 3 â Y – — è
I_CORE_QUERY_USER_BY_MOBILE	D j k Ý © • ž	9 : • 0 1 ¸ © I G n
I_CORE_QUERY_STAFF_INFO_DETAIL	Ó ¥ Û Ü	’ Æ • Ó
I_CORE_SHOW_PARENT	‡ ˆ	Y À ¨ Ý Þ •
I_CPCS_CHARGE_BIZ_QUERYBALANCE	Ô á © I	Ü ž Ô á ô •
I_CPCS_CHARGING_GET_CHARGE_USER_INFO	• ž	Ì Ü ž Û Ü
I_BSM_OMS_GET_DETAIL_AND_ORDER	ß ¶ Û Ü	Ñ © ß ¶
I_BDM_MOBILESTUDENT_FINDBYUSER	D • ž © À ¨	À ¨ à á ¿ í © I
I_BSS_QUERY_SCHOOL_MERCHANT	À ª ž © I	ª ž € î ï ¦ §

E 5-1 † ‡ Y * ¸ Œ • RPC G n â • 114 G n Å õ é Õ ± 12 è

G n Ò µ ¶ € … ¸ ’ Æ ± P å À ˆ ‰ å • ¸ “ I ” • Å ' $ ¯ Å Z [\ • " x G n Q 2 ¸ Æ î ¶ T . $ † ‡ 0 1 Ö \ ; Y â ¸ ã ä Ï Ð ‡ ¹ € G n û – • ž - - R " ; û 2 î ˆ ‰ å • æ á ð ñ ¸ Æ Ö

—8 € TLS ¼ · ½ j ¨ ¸ ° ± : ƒ ! ® Ó Ö — 8 œ R K ¸ § ¦ o DV — 8 Å c d etonedu.cn Æ i Ñ Å i N k „ œ ö § â WoTrus è Ú

° ± 6-2 € ' W 6-2 — 8

```
echo | openssl s_client -connect m-web.etonedu.cn:443 \
  -servername m-web.etonedu.cn 2>/dev/null \
  | openssl x509 -noout -subject -issuer -dates
subject=CN=*.etonedu.cn
issuer=C=CN, O=WoTrus CA Limited, CN=WoTrus DV Server CA
notBefore=Dec 10 00:00:00 2025 GMT
notAfter=Jan 10 23:59:59 2027 GMT
```

° ± 6-3 € ' W 6-3 ÷ ¼ TLS ½ j ¨

```
for v in tls1 tls1_1; do
  if echo | openssl s_client -connect m-web.etonedu.cn:443 \
       -servername m-web.etonedu.cn -$v 2>/dev/null | grep -q "Verify return code"; then
    echo "$v: handshake OK"
  else
    echo "$v: rejected"
  fi
done
tls1:    handshake OK
tls1_1:  handshake OK
```

TLS 1.0 € TLS 1.1 T p Ÿ ½ j Ö " ¼ · ø $ 2018 â RFC 8996 è . - ; H ù ú Å ˆ ' œ ¢ ö â PCI-DSS å m ® î > è T î > (û TLS 1.2 :] ƒ Ö ÷ ¼ Ø Ù ¸ ë $ œ Â • è] ê û • û « § Ç Å ¬ ä ™ „ ® 8 o ' á Ö

6.3 š ›

¹ /post ¿ N ¯ % & ü Z ý 5 ¸ CORS ã ¨ = > Å ¨ – ™ š û J Z Z ý 5 1 { þ Ñ ô • Ú

° ± 6-4 € ' W 6-4 CORS ã ¨

```
curl -s -o /dev/null -D - -X OPTIONS "https://m-web.etonedu.cn/post" \
  -H "Origin: https://evil.example.com" \
  -H "Access-Control-Request-Method: POST" \
  -H "Access-Control-Request-Headers: content-type"
# ‰ Š ›  HTTP/1.1 200 OK  œ Access-Control-Allow-Origin • ž ‡
```

ã ¨ - 6 Y ¿ Ø Z [Access-Control-Allow-Origin 7 Å ê ^ API Ñ w ñ ² 5 ò ó Y - { 1 Å ...G • , J n $ @ A B ' ä ™ ô • ™ š - 6 Ö " û á , ³ ì ¸ ¦ § Å € 6.1 & ¸ WAF å R K — 8 L × Û ; J N Ö

6.4 š › ƒ

· ¨ © ¸ ú ÿ û „ … ± € ¦ § ± ¸ ^ Ø Ú Û š é R WAF € R K — 8 ë Å X 6 • ± 7 ö å ÷ ¼ TLS Y ñ å Ù • u ç 0 1 Ö " * Ñ ¸ ? é û · Ì â ú (2

· . – — ¸ 8 „ ä ™ Đ • Ï Đ B ‰ â ó ˆ ‰) › ÿ ± è ¸ É Ê Å " é { ^ ð E] ¨ ¿ Ö . – — • ð Â $ ú ² , € Ù Đ , Ú Ã ” € … x Z Z RPC = > ù ú å o Ò • Ü Ý – G n å Ÿ R K Ü Ý å] : ½ 0 L Ý ² € ’ • Ž Ö " x • ð ^] x •) * å ‹ Œ € î ï Ù Đ u Å X 8 m ² È ÷ Ï Đ B · : Ö

§ Ï Đ B ± , ¸ $. â Í Þ É Ê û š Y – — ¸ ¢ É Ú MR-02 ¸ s ` SSRF â ž ‡ p ¸ url y N n è t - — S p u J ’ " N Å Á] ê p Ï Đ B ÿ j ’ Å Ô] SR-01) * ¸ Redis š ± â 172.16.50.31:13697 è ~ ÿ ± a ë Ï Đ Å } ì Ë Redis ¦ § € Æ Ç K 3 I • í ë s " Ö ¢ š • ³ Y – — Å Z [³ K Á É Ê 8 § Ö ‡ õ Š ð ¸ ƒ « û Ú õ † — ² î } ¸ ¬ - È Ù Đ € ú ² ± Å Ï Đ B ± , v w ë $ p • r X Y ÷ — S Å ð ñ Á È ˆ ‰ ‹ Œ ¸ ¥ , ¾ C Ö

7.3 0 · Ì 1 2 3

· Æ + , p D & ³ $ ² „ ³ ´ Ú ¸ • , “ Õ € = > ü ý å … ¸ š curl Ó Õ € … š rg ¨ Â

6 7	ó 8	9
capture.js	XHR » . + » Ä · â ˜ è	1.4 KB
findings.md	¡ ó ƒ « ` ±	2.3 KB
hfRecharge_home.png	• , • í ú â ë È download Ì ± è	90 KB
cover.html / cover.pdf	· $, 5 X 1 € %	44.6 KB

E A-1 — ² X 1 µ ¶

A.2 : Í ; › <

] Ó D & Ð Æ ¿ À ° ± Å £ · & Â Ö ° ± Â ¸ Ì " N T œ · ô S t F • ¸ Ú

```
° ± A-1 ò ó ° ± & ©

# Ÿ ¡ ¢ £ ¤ ¥ ¦ … † § ¨
agent-browser set device "iPhone 14"
agent-browser open "https://m-web.etonedu.cn/mfinm/?visitId=1790161526056%7C26#/hfRecharge/home"
agent-browser snapshot -i
agent-browser network requests
agent-browser cookies && agent-browser storage local
# Ÿ © ¡ ª « ¥ ¦ ¬ -
curl -s "https://static.etonedu.cn/statics/wxedu/mfinm_v0.1/static/js/app.06685cf4bb1b7f0cf36c.js" -o app.js
rg -o "wxapp_secrets:\{[^}]{0,900}" app.js
rg -o "redissettings:\{[^}]{0,120}\}[^}]{0,60}" app.js
rg -o "(172\.|10\.|192\.168\.)[0-9.]+:[0-9]+" app.js | sort -u
# Ÿ ® ¡ ¤ ¯ ° ¦ €
rg -o ".{200}AES\.encrypt.{260}" app.js
python3 verify_aes.py
# Ÿ ± ¡ ² ³ ´ µ ¦ ¶ ·
curl -s -X POST "https://m-web.etonedu.cn/mfinm/getLoginInfo" -H "Content-Type: application/json" \
  -H "Origin: https://m-web.etonedu.cn" -d '{"visitId":"1790161526056|26"}'
agent-browser eval "$(cat capture.js)"
agent-browser fill @e5 "00000000" && agent-browser click @e4
rg -o '"I_[A-Z_]{4,60}"' app.js | sort -u | wc -l
# Ÿ ¸ ¡ ¹ º » ¼ ¬ ½
curl -sI "https://m-web.etonedu.cn/mfinm/?visitId=1790161526056%7C26"
echo | openssl s_client -connect m-web.etonedu.cn:443 -servername m-web.etonedu.cn 2>/dev/null \
  | openssl x509 -noout -subject -issuer -dates
curl -s -o /dev/null -D - -X OPTIONS "https://m-web.etonedu.cn/post" \
  -H "Origin: https://evil.example.com" -H "Access-Control-Request-Method: POST"
```